

Vulnerability Assessment Report - OWASP Juice Shop

Executive Summary

This report documents the successful identification and exploitation of a **critical Broken Access Control** vulnerability, specifically an **Insecure Direct Object Reference (IDOR)**, within the OWASP Juice Shop application. By intercepting and manually modifying the basket ID in an HTTP request using **Burp Suite**, an authenticated user was able to access and view the shopping basket contents belonging to another user, including the **administrator** (admin@shop.in).

1. Broken Access Control (A01:2021) - Insecure Direct Object Reference (IDOR) on Basket

Description

The application uses a **sequential, exposed identifier** in the API endpoint path (/rest/basket/{id}) to retrieve a user's basket data. The application fails to perform a **server-side authorization check** to confirm that the requesting user (identified by their session token) is the legitimate owner of the basket ID specified in the URL path. This allows an attacker to easily exploit the IDOR vulnerability by simply enumerating or guessing other users' basket IDs.

Evidence

The Burp Suite captures clearly demonstrate the attack vector:

- Request Observation (File 01.jpg):** The image shows an initial request related to the basket being intercepted in Burp Suite, likely for the user's own basket or a placeholder.
- IDOR Attack Execution (Files 02.png and 03.png):** The attacker intercepts the request and **manually changes the basket ID** in the URL path to a target ID, specifically **13**:
 - Modified Request:** GET /rest/basket/13 HTTP/1.1
- Successful Unauthorized Access (File 04.jpg):** The server returns a successful 200 OK response with the JSON data for basket ID **13**. This data includes product details ("Carrot Juice," "Eggfruit Juice"), confirming the unauthorized retrieval of another user's basket contents.
- Visual Confirmation (Files Basket-01.jpeg and Basket-02.png):** The browser subsequently renders the retrieved data, displaying a basket associated with the email address **admin@shop.in** and showing items with a total price of **11.98€**. This confirms that the attacker, who was logged in as a non-administrator, successfully accessed the **administrator's private shopping basket**.

Attribute	Detail
Vulnerability Type	Broken Access Control (IDOR)
OWASP Top 10 Mapping	A01:2021 - Broken Access Control
Impact Level	High 

Attribute	Detail
Impact	Allows an attacker to view the private shopping details of any other user, including admin or privileged accounts. This represents a serious data privacy breach and could be used for intelligence gathering or fraud.

Mitigation Steps

The application must enforce strict authorization checks on all direct object references:

1. **Enforce Server-Side Authorization:** Implement code that strictly verifies that the **authenticated user's ID (from the session token)** matches the **owner of the basket ID** being requested in the URL. If they do not match, the server must reject the request with a **403 Forbidden** response.
2. **Use Indirect References:** Replace the predictable, sequential database IDs (like 13) in the URL path with **per-user, non-guessable, non-sequential references** such as a randomly generated **UUID (Universally Unique Identifier)** or a masked ID. This makes it impossible for an attacker to enumerate other users' data.

OWASP Top 10 Compliance Checklist Mapping

OWASP Top 10 (2021)	Vulnerability Found	Status
A01: Broken Access Control	IDOR on Basket Endpoint	Found
A02: Cryptographic Failures	Not Tested/Found	Not Applicable
A03: Injection	Not Tested/Found	Not Applicable
A04: Insecure Design	Not Tested/Found	Not Applicable
A05: Security Misconfiguration	Not Tested/Found	Not Applicable
A06: Vulnerable and Outdated Components	Not Tested/Found	Not Applicable
A07: Identification and Authentication Failures	Not Tested/Found	Not Applicable
A08: Software and Data Integrity Failures	Not Tested/Found	Not Applicable
A09: Security Logging and Monitoring Failures	Not Tested/Found	Not Applicable
A10: Server-Side Request Forgery (SSRF)	Not Tested/Found	Not Applicable

Tools Used

- **Target Application:** OWASP Juice Shop
- **Web Application Testing Toolkit:** Burp Suite Community Edition (Used to intercept and modify HTTP requests)
- **Operating System:** Kali Linux (Running in VirtualBox)

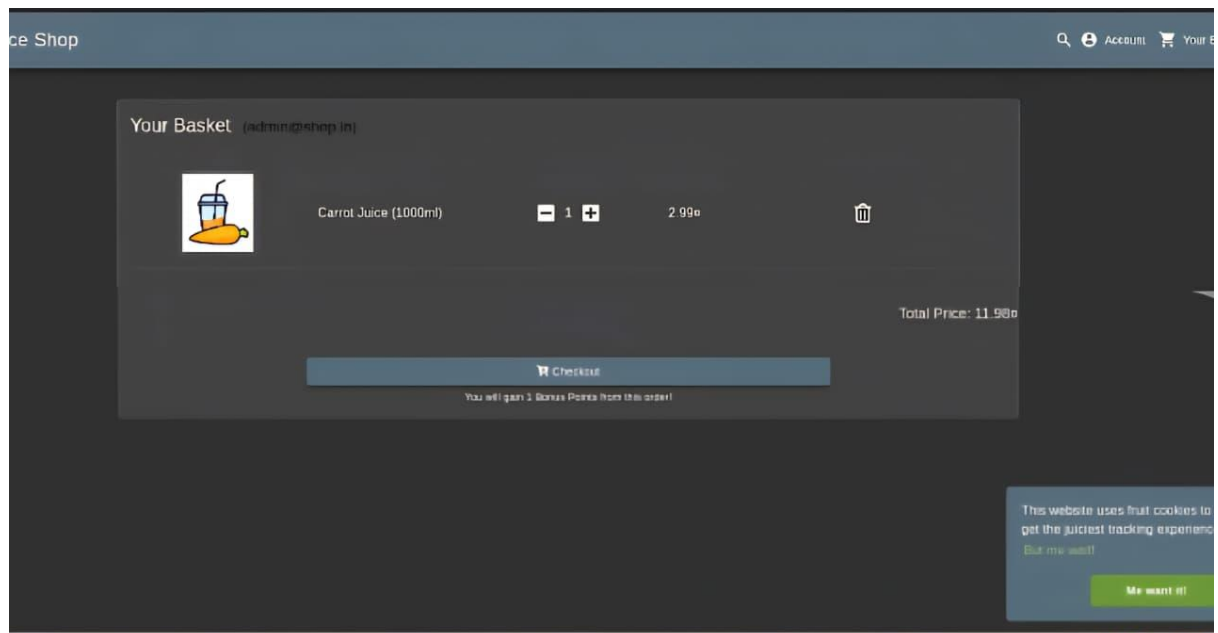
01

The screenshot shows the Burp Suite Community Edition v2025.5.3 interface. The target is set to https://juice-shop.herokuapp.com. A request is intercepted and the 'Send to Repeater' option is selected. The request details show a GET request to https://juice-shop.herokuapp.com/rest/basket/1 with a token in the cookies.

02

The screenshot shows the Burp Suite Community Edition v2025.5.3 interface. The target is set to https://juice-shop.herokuapp.com. A request is intercepted and the 'Send to Repeater' option is selected. The request details show a GET request to https://juice-shop.herokuapp.com/rest/basket/1 with a token in the cookies.

Basket (Before)



Basket (After)

